

# DevSecOps

Uno de los objetivos de DevOps es ofrecer actualizaciones de software rápidas y de alta calidad. Y para que el software sea de alta calidad, debe cumplir con estrictos requisitos de ciberseguridad. Ahí es donde entra en juego la seguridad de DevOps, o DevSecOps. En esta lectura analizarás DevSecOps, sus controles de seguridad y su dependencia de la automatización.

## ¿Qué es DevSecOps?

**DevSecOps** es una extensión de DevOps que automatiza las comprobaciones de seguridad a lo largo del SDLC para evitar vulnerabilidades en el producto final. Una **vulnerabilidad** es una posible debilidad, como la ausencia de cifrado de datos, que alguien puede explotar en un sistema.

Tradicionalmente, los desarrolladores escribían la mayoría del código de producción sin tener en cuenta la seguridad, y un equipo de seguridad comprobaba el software únicamente al final del SDLC. Este método funciona cuando las actualizaciones se producen solo unas cuantas veces al año, pero los equipos de DevOps producen actualizaciones cada pocas semanas o incluso con más frecuencia.

Con DevSecOps, los desarrolladores incorporan la seguridad en cada paso del SDLC. Los equipos tienen en cuenta y planifican las posibles amenazas de seguridad desde el principio, y prueban, escanean, auditan y revisan el código a lo largo del desarrollo.

## Componentes

Los componentes clave de DevSecOps incluyen la responsabilidad compartida, la velocidad y la calidad, los controles de seguridad y la automatización.

### Responsabilidad compartida

En DevSecOps, todos (los equipos de desarrollo, operaciones y seguridad) comparten la responsabilidad de la seguridad.

- Deben comprender la seguridad básica de las aplicaciones y las estrategias de mitigación.

- Deben seguir las actualizaciones del [Top 10 del Open Web Application Security Project \(OWASP\)](#), una lista de referencia del sector que enumera los riesgos de seguridad críticos para las aplicaciones web.
- Los desarrolladores deben acordar y seguir prácticas de codificación seguras.

## Velocidad y calidad

Los problemas de seguridad de la aplicación requieren tiempo y dinero para solucionarse, especialmente los que se hallan al final del SDLC, y pueden retrasar considerablemente el lanzamiento.

Con DevSecOps, los equipos tienen en cuenta la seguridad ya desde la etapa de planificación, e identifican y abordan los problemas de seguridad de manera temprana y rápida, lo que les permite seguir ofreciendo actualizaciones pequeñas, continuas y de alta calidad.

## Comprobaciones de seguridad

Con DevSecOps, el software se somete a numerosas comprobaciones de seguridad a lo largo de todo el SDLC. Veamos algunas comprobaciones estándar.

- **El modelado de amenazas** es un proceso en el que los equipos identifican y categorizan las amenazas de seguridad para tenerlas en cuenta en el desarrollo y el soporte de software. El modelado de amenazas suele producirse durante la fase de diseño o planificación del desarrollo, antes de que los desarrolladores escriban el código.
- **Los análisis de vulnerabilidades** identifican las vulnerabilidades de la aplicación y de las bibliotecas (colecciones de código reutilizable) de las que depende la aplicación. Los equipos pueden automatizar la aplicación de parches para abordar las vulnerabilidades lo antes posible. Dos análisis de vulnerabilidades comunes son las pruebas de seguridad de aplicaciones estáticas y las pruebas de seguridad de aplicaciones dinámicas.
- Las herramientas de **pruebas de seguridad de aplicaciones estáticas (SAST)** analizan las vulnerabilidades dentro del código y sus bibliotecas. «Estática» significa que la aplicación no se está ejecutando, sino que se encuentra en reposo.
- Las herramientas de **pruebas de seguridad de aplicaciones dinámicas (DAST)** detectan vulnerabilidades observables fuera del código mientras se ejecuta la aplicación. Para ello, estas herramientas simulan técnicas de hackeo reales, como la inyección SQL, para descubrir puntos débiles que los ciberdelincuentes pueden explotar.

- Los **escaneos de secretos** buscan secretos que los desarrolladores dejan accidentalmente en el código o en los archivos de configuración. Los secretos son credenciales confidenciales, como contraseñas y claves de cifrado, y las organizaciones deben protegerlos frente a filtraciones. Si los secretos se cuelan en la base de código de la aplicación, los ciberdelincuentes podrían encontrarlos.
- Las **pruebas unitarias** son pruebas que evalúan un solo componente o unidad de una aplicación para comprobar que el componente funciona correctamente. Estas pruebas se ejecutan cuando los desarrolladores envían código nuevo para su integración en la base de código principal del software. En DevSecOps, los desarrolladores diseñan pruebas unitarias adicionales, denominadas **pruebas unitarias de seguridad**, que comprueban si existen problemas de seguridad.
- Las herramientas de **monitorización de seguridad** supervisan las aplicaciones en vivo para detectar problemas de seguridad, como ataques cibernéticos, y envían alertas inmediatas cuando ocurre dicha actividad. De esta manera, el personal puede responder rápidamente para minimizar el daño y parchear la aplicación en caso necesario.

## Automatización

La automatización es esencial para DevOps, y DevSecOps no es una excepción.

Las herramientas de integración continua y entrega continua (CI/CD) pueden automatizar los controles de seguridad en casi todas las etapas del SDLC, lo que permite que todos puedan centrarse en otras tareas.

- Las herramientas de automatización verifican que el código pasa las pruebas unitarias de seguridad y que las dependencias de software cuentan con los parches más recientes.
- Las herramientas SAST detectan las vulnerabilidades en el código nuevo antes de que los desarrolladores lo incorporen a su base de código.
- Las herramientas DAST evalúan las actualizaciones en un entorno de preproducción.
- Las herramientas pueden automatizar la configuración de sistemas y servicios, garantizando así el cumplimiento de la seguridad y reduciendo los errores humanos.